Guion de la exposición

Agente Supervisor de Consentimientos (AGT-CONSENT-01) · Grupo C · Auditoría de Sistemas

Daniel

Diapositiva 1 · Agente Supervisor de Consentimientos

Saludo, nombre del curso y del grupo. Presentar el tema en una frase: construimos un agente de inteligencia artificial que revisa formularios y políticas de privacidad y dictamina si cumplen las normas de protección de datos personales en lo referente al consentimiento. Mencionar que la presentación se divide en tres partes, una por integrante.

Diapositiva 2 · Cómo nos repartimos la exposición

La exposición sigue los niveles de la rúbrica del profesor: Daniel presenta el diseño del agente (objetivo, datos, contexto y herramientas); Jhastyn, la arquitectura y cómo se orquestan skills, herramientas y flujos; y Daniela muestra el proyecto funcionando en vivo con el panel y los resultados.

Diapositiva 3 · Auditar el consentimiento a mano es lento y propenso a errores

Explicar el problema que plantea el TIF: verificar manualmente si los formularios, las políticas de privacidad y los registros cumplen la ISO 27701 y la Ley 29733 es lento y propenso a omisiones. Además, hay excepciones legales (Art. 14) donde no se necesita consentimiento, y si no se revisan primero se acusa a la empresa de incumplir cuando no corresponde. Por último, usar solo un chatbot no sirve porque puede alucinar: inventar artículos o citar cosas que no están en el documento.

Diapositiva 4 · Evaluar una evidencia documental y emitir un dictamen por dominio —Conforme, No Conforme o No Aplica— con la norma aplicada, la cita de la evidencia y las medidas correctivas.

Leer el objetivo. El agente recibe una evidencia (por ejemplo, el texto de un formulario web y su política de privacidad) y devuelve un informe con un dictamen por dominio. Las normas: de la ISO 27701, los controles sobre propósito (A.1.2.2), cuándo y cómo obtener el consentimiento (A.1.2.4), obtenerlo y registrarlo (A.1.2.5), información al titular (A.1.3.3 y A.1.3.4) y retiro del consentimiento (A.1.3.5). De la Ley 29733: el principio de consentimiento (Art. 5), que debe ser previo, informado, expreso e inequívoco (13.5), las excepciones (Art. 14) y el derecho de información (Art. 18).

Diapositiva 5 · Objetivo, datos, contexto y herramientas

Esta diapositiva responde al primer nivel de la rúbrica. Objetivo: lo de la diapositiva anterior. Datos: el corpus normativo está en config/corpus_normativo.json (20 fragmentos de la ISO y la Ley) y las evidencias a auditar se cargan manualmente como archivos de texto en la carpeta evidencias/, que es como el profesor pidió subir la información. Contexto: la ficha del agente en .opencode/agent/consent-supervisor.md define su identidad, sus instrucciones, sus reglas y el formato JSON de salida; además están las reglas de auditoría (consent_rules.json) y las excepciones del Art. 14. Herramientas: el agente expone 5 herramientas MCP, que también pueden usar otros agentes.

Diapositiva 6 · La norma se divide por artículo y por control

Explicar el chunking estructural del TIF (sección 3.4). En vez de cortar el texto cada cierto número de caracteres, cortamos por unidad lógica: un artículo de la ley o un control de la ISO. El Art. 14, que enumera las excepciones, se divide por numeral y cada pedazo lleva la cabecera del artículo, para que el agente sepa que es una excepción. Cada fragmento lleva metadatos: la norma, el artículo o control, y la naturaleza (requisito, guía o excepción). Ese campo naturaleza es el que permite el paso Fail-Fast. Aclarar: por derechos de autor de la ISO, los textos son resúmenes del equipo; si se tienen los PDF oficiales con texto, el agente los incorpora literalmente. Aquí termina Daniel y pasa la palabra a Jhastyn.

Jhastyn

Diapositiva 7 · Cuatro capas, todo corre en el equipo del auditor

Jhastyn empieza con la arquitectura. Recorrer el diagrama de izquierda a derecha. A, fuentes: la evidencia que se carga a mano, el corpus normativo, las reglas y las excepciones del Art. 14, y el índice de Qdrant. B, capa MCP: un servidor con 5 herramientas que separa el agente de sus fuentes; también lo pueden usar otros agentes u OpenCode. C, núcleo: los 5 pasos que vamos a ver ahora (Fail-Fast, búsqueda, reglas, Llama 3 y guardas). D, gobernanza: si no hay dudas se emite; si las hay, pasa a la cola del auditor, que aprueba o rechaza. Todo corre en la laptop, sin Docker ni internet: Qdrant embebido y Llama 3 en Ollama. El detalle completo está en el Informe de Arquitectura que entregamos aparte (contexto, componentes, secuencia y despliegue).

Diapositiva 8 · Un flujo automático en seis pasos

Presentar el flujo completo que el agente ejecuta solo, sin intervención: (1) Fail-Fast: revisa primero si aplica una excepción legal. (2) Búsqueda híbrida: trae los artículos y controles relevantes para cada dominio. (3) Reglas: un motor determinista detecta problemas concretos en la evidencia. (4) El LLM local razona en los cuatro pasos del TIF. (5) Guardas: se verifica que lo que dice el LLM sea cierto. (6) Si todo está claro se emite el informe; si hay dudas pasa a revisión humana. Esto corresponde al segundo nivel de la rúbrica: orquestación y automatización.

Diapositiva 9 · Primero las excepciones, después los controles

El Fail-Fast es la idea central del TIF (sección 3.2). Antes de revisar si hay consentimiento, el agente consulta solo los fragmentos marcados como excepción del Art. 14. Si el caso encaja, por ejemplo abrir una cuenta bancaria, no se exige consentimiento y los dominios de obtención y revocación quedan como No Aplica; pero la empresa igual debe informar al titular, así que ese dominio sí se evalúa. Si el caso es comercial, como una tienda que envía promociones, ninguna excepción aplica y se evalúa todo. Regla importante: aunque haya indicios de contrato, si también hay publicidad o perfilamiento, la excepción no cubre esos fines.

Diapositiva 10 · Búsqueda por significado y por palabra exacta

Explicar la búsqueda híbrida del TIF (sección 3.5). La búsqueda densa convierte el texto en vectores y encuentra fragmentos parecidos en significado. La búsqueda dispersa BM25 encuentra coincidencias exactas de términos legales y códigos, que los vectores tienden a diluir. Las dos listas se fusionan con Reciprocal Rank Fusion y luego un Cross-Encoder multilingüe (bge-reranker) reordena los candidatos y deja solo los mejores. Todo vive en Qdrant, que corre dentro del proyecto sin necesidad de Docker. Además, cada paso filtra por metadatos: por ejemplo, el dominio de revocación solo busca en el control A.1.3.5 y el Art. 5.

Diapositiva 11 · Cómo se coordinan las piezas

Este es el núcleo del segundo nivel de la rúbrica: coordinación de skills, agentes y flujos. El agente tiene su ficha en .opencode/agent, con su identidad y protocolo. El skill en .opencode/skills describe el proceso reutilizable. El servidor MCP publica las herramientas para que opencode u otro agente las invoque. La salida es un JSON estandarizado, con la misma estructura que usa el agente Data Bridge del grupo, para que otro agente (por ejemplo uno de riesgos) pueda consumirla. Y run_demo.py automatiza todo el proceso de principio a fin. Seguimos exactamente la misma estructura que el agente de referencia del grupo.

Diapositiva 12 · El skill consent-audit funcionando en OpenCode

Esta es la parte central del segundo entregable: convertir el protocolo del agente en un skill reutilizable. Se probó en OpenCode: ante un pedido que no mencionaba el skill, OpenCode lo reconoció y lo activó solo, ejecutó la auditoría de TiendaAndina por consola y, en otra conversación, usó la herramienta MCP de auditoría completa; el resultado quedó pendiente del auditor con su huella y ticket. Aclarar la pregunta frecuente de qué IA usa: hay dos. El asistente de OpenCode usó un modelo en línea (ChatGPT, con la cuenta del integrante); el motor que emite el dictamen es local: reglas, búsqueda híbrida y Llama 3 en Ollama.

Diapositiva 13 · El LLM opina; las reglas y el auditor deciden

Las guardas revisan todo lo que dice el LLM. Solo se aceptan citas copiadas literalmente del documento; las paráfrasis se descartan y, si el LLM no aporta ninguna cita literal, su redacción no entra al informe. Toda norma citada debe haber sido recuperada. Si el LLM opina distinto que las reglas, se mantiene el dictamen de las reglas y se adjunta su opinión. El informe no se emite solo y pasa al auditor cuando: se aplicó una excepción, faltan datos o hay contradicciones, falta contexto normativo, hay instrucciones maliciosas o el LLM discrepa. El agente apoya al auditor, no lo reemplaza. Aquí termina Jhastyn y pasa la palabra a Daniela.

Daniela

Diapositiva 14 · Seis fallas detectadas y corregidas

En el segundo entregable probamos el agente buscando fallas a propósito y encontramos seis. Por ejemplo, si un formulario solo decía «Destinatarios:» sin completar, el agente lo daba por cumplido; o una empresa llamada Centro de diagnóstico activaba por error la excepción de salud del Art. 14 solo por su nombre. Cada falla se corrigió y tiene una prueba automática que la vigila, de modo que no vuelva a aparecer. Esto muestra un proceso de auditoría del propio agente.

Diapositiva 15 · El panel del auditor

Antes de la exposición: Ollama abierto y el panel ya levantado con python dashboard.py. Pasos: 1) elegir tiendaandina y pulsar Auditar; 2) mientras corre (unos 2 minutos con Llama 3) explicar la matriz: cada fila es un dominio y cada columna un paso; el visto es que está bien y el signo de exclamación es un problema; 3) mostrar el resultado: No conforme, pendiente de revisión, con un problema y una cita por dominio; 4) abrir Ver informe (PDF); 5) en Revisión del auditor leer qué hay que verificar y pulsar Aprobar o Rechazar. Si no hay tiempo o falla Ollama: python dashboard.py --sin-llm tarda segundos. Esta captura sirve de respaldo si algo falla.

Diapositiva 16 · Una solución integrada que funciona de punta a punta

Después de la demostración, resumir cómo se usa: la data se carga manualmente, como indicó el profesor, guardando el texto en evidencias/ o pegándolo en el panel. La auditoría se lanza desde el panel web (python dashboard.py) o por consola (python run_demo.py, rag_auditor.py). Todo corre en la laptop: Qdrant embebido y Llama 3 en Ollama, sin internet. Los resultados salen como informe PDF, Excel con todos los dictámenes, matriz de evidencias y cola del auditor. Hay 46 pruebas automáticas aprobadas y validar_skill.py comprueba los 5 casos sin simular decisiones humanas.

Diapositiva 17 · Cinco casos, cinco comportamientos esperados

Cinco casos, cada uno diseñado para probar algo distinto. TiendaAndina, el caso del TIF, sale No Conforme en todo y queda para el auditor porque no consta canal de derechos ni mecanismo de baja. Banco Andino prueba el Fail-Fast: abrir una cuenta es una relación contractual. LibreríaSur cumple todo: sin LLM se emite automáticamente; con llama3 pasa al auditor porque el modelo opinó distinto, y se mantiene el Conforme de las reglas. ClubFit tiene una instrucción oculta y no logra engañar al agente. El formulario incompleto, nuevo en este entregable, prueba que poner solo el título de un requisito no basta. Dato para mencionar: validar_skill.py comprobó los 5 casos (5 de 5) sin simular decisiones del auditor.

Diapositiva 18 · El informe reproduce la tabla 3.7 del TIF

Abrir en vivo el archivo out/informe_caso_tiendaandina.md o mostrar esta tabla. El agente llega a los mismos dictámenes que planteamos en la tabla 3.7 del TIF: finalidad genérica, casilla premarcada y agrupada con la política, sin registro de fecha y hora, y revocación solo por teléfono. Cada fila indica la cita textual de la evidencia y la norma usada, y las medidas salen priorizadas como en el TIF: rediseñar el formulario, registro auditable, revocación por el mismo canal, reescribir el aviso y reauditar en 30 días.

Diapositiva 19 · Un LLM local no basta como juez

Contar lo que encontramos al probar con el LLM real. Medimos 10 decisiones: 4 del paso Fail-Fast y 6 dictámenes por dominio. llama3 acertó 8 y llama3.1 acertó 6. Los errores siempre fueron del mismo tipo: decir No Conforme en un caso que sí cumplía, inventando requisitos. Por eso el agente no confía ciegamente en el LLM: las reglas verificables deciden el dictamen provisional y, si hay diferencia, el caso pasa al auditor. Esto también sustenta la conclusión del TIF de que el agente es una herramienta de apoyo y no reemplaza al auditor.

Diapositiva 20 · Un agente funcional, con el auditor al centro

Lo logrado: el agente está diseñado, el skill funciona en OpenCode, el flujo es automático con Fail-Fast y búsqueda híbrida, se probaron 5 casos con 46 pruebas aprobadas, se mostró en vivo con el panel y el informe sale en PDF y se corrigieron seis fallas de seguridad. Lo pendiente queda para la tercera unidad: orquestarlo con los otros agentes del grupo (por ejemplo, que el agente de inventario le pase las actividades basadas en consentimiento), usar el texto literal de la ISO y verificar el Art. 14 contra el texto oficial, ampliar las reglas, probar modelos más precisos y validar con casos reales. Agradecer y abrir a preguntas.